COMPTIA SECURITY+ SY0-701 | DOMAIN 5 · SECURITY PROGRAM MANAGEMENT AND OVERSIGHT (20%)

Security+ 5.3 · Agreement Types

Mestre CyberSec · **Lesson 5.3 — Agreement Types** (5:19) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

> **Executive Lesson Summary:** SLA: métrica de serviço + PENA se faltar (99,9% uptime); MOU/MOA (intenção); NDA (confidencialidade); BPA (parceria formal).

💡 Key Exam Highlights & Critical Concepts

- SLA: métrica de serviço + penalidade se falhar

🎯 Exam Tips & Typical CompTIA Scenarios

- 'agreement defining service level penalty'=SLA

🚨 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 5.3 — Agreement Types)

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• Service Level Agreement (SLA)

A binding contract that defines specific, measurable service performance metrics (such as 99.9% uptime) and the financial penalties or remediation actions owed to the customer when those metrics are not met.

⚠️ ***Exam Trap:*** *Trigger phrase: 'agreement with penalties for missing service metrics' or 'defines uptime guarantees' = ALWAYS SLA. The penalty/remediation clause is the key differentiator from MOU/MOA.*

• Memorandum of Understanding (MOU)

A non-binding document that expresses the mutual intent and willingness of two parties to work together toward a common goal, commonly used between organizations before a formal contract is signed.

⚠️ ***Exam Trap:*** *Trigger phrase: 'intent to cooperate' or 'non-binding agreement between organizations' = MOU. Crucially, MOUs have NO penalties and are NOT legally enforceable like an SLA.*

• Memorandum of Agreement (MOA)

A document that outlines the terms and details of an agreed-upon arrangement between parties, more formal and specific than an MOU but typically less binding than a full contract.

⚠️ ***Exam Trap:*** *Exam trap: MOA vs MOU are very similar — if the question specifies 'detailed responsibilities' or 'cooperative research/project work,' choose MOA; if it specifies 'general intent' between organizations, choose MOU.*

• Non-Disclosure Agreement (NDA)

A legally binding contract that establishes a confidential relationship between parties, prohibiting the sharing of proprietary, sensitive, or classified information with unauthorized third parties.

⚠️ ***Exam Trap:*** *Trigger phrase: 'protects confidential information,' 'prevents sharing of trade secrets,' or 'employee/contractor confidentiality' = ALWAYS NDA. One-way (unilateral) or mutual (bilateral) variants both exist.*

• Business Partnership Agreement (BPA)

A formal, legally binding contract between two or more business partners that defines profit/loss sharing, management responsibilities, and the legal structure of their joint venture.

⚠️ ***Exam Trap:*** *Trigger phrase: 'formal partnership,' 'defines roles and profit sharing between businesses,' or 'joint venture terms' = BPA. Exam tip: must be signed BEFORE sharing confidential info — always pair with an NDA.*

• Master Service Agreement (MSA)

A top-level umbrella contract that establishes the general terms and conditions under which multiple specific Statements of Work (SOWs) will be executed between a client and vendor.

⚠️ ***Exam Trap:*** *Trigger phrase: 'umbrella agreement governing multiple future projects' or 'framework contract with vendor' = MSA. The MSA reduces negotiation time for each new project because terms are pre-agreed.*

- **Statement of Work (SOW)**

A detailed document that defines the specific deliverables, timeline, milestones, and acceptance criteria for an individual project executed under a broader MSA or contract.

⚠️ ***Exam Trap:*** *Trigger phrase: 'defines specific project deliverables and timeline' = SOW. Distinguish from SLA: SOW defines WHAT is delivered; SLA defines HOW WELL it is delivered (with metrics/penalties).*

🏛️ Conceptual Deep Dive, Real-World Analogies & GRC Analysis

📌 Service Level Agreement (SLA)

🏠 **Real-World Analogy:** Contracting an emergency diesel generator for a packed stadium championship match. The contract establishes in exact numerical terms a mandatory 99.99% uptime guarantee; if power collapses for over 30 seconds, the provider is contractually liable to pay an immediate $500,000 penalty to reimburse tickets. It sets enforceable operational metrics backed by monetary penalties.

🔍 **Root Cause & Background:** Service providers casually promising near-perfect availability verbally, but taking days to remediate outages when no binding monetary penalties exist in signed contracts.

🛡️ **GRC Auditor Perspective:** Audit contractual SLA language: confirm that uptime thresholds (e.g. 99.9%), mean time to restore clauses, and financial service credits are mapped to automated, auditable monitoring telemetry.

⚠️ **How CompTIA Tests This:** Exam trigger: 'contract specifying guaranteed performance metrics, uptime percentages, and financial penalties for non-performance' = Service Level Agreement (SLA).

📌 Non-Disclosure Agreement (NDA)

🏠 **Real-World Analogy:** The binding pact of secrecy signed by engineers invited to beta-test a confidential next-generation smartphone prototype before Apple's worldwide launch event: the legal document dictates that any leaked photo, spec discussion, or social media hint triggers multi-million-dollar lawsuits and immediate contract termination.

🔍 **Root Cause & Background:** The severe exposure of prospective business partners, contractors, or new staff siphoning proprietary source code, blueprints, and formulas to sell to market competitors.

🛡️ **GRC Auditor Perspective:** Verify that bilateral or unilateral NDAs are executed PRIOR to any exchange of confidential architecture blueprints or pre-contract technical roadmaps.

⚠️ **How CompTIA Tests This:** Exam trigger: 'legal agreement between parties designed to protect proprietary information and intellectual property from unauthorized disclosure' = Non-Disclosure Agreement (NDA).

📌 Memorandum of Understanding (MOU) vs Memorandum of Agreement (MOA)

🏠 **Real-World Analogy:** An informal engagement announcement versus a notarized prenuptial agreement. An MOU is the mutual handshake at a family dinner where parties express cordial future intentions to collaborate (non-binding, without immediate financial commitments). An MOA is the notarized, legally enforceable agreement detailing precise shared obligations, resources, and operational milestones.

🔍 **Root Cause & Background:** The requirement to formalize preliminary mutual intent and cooperation between government agencies or enterprises before incurring massive legal expenses for binding master contracts.

🛡️ **GRC Auditor Perspective:** Verify that preliminary MOUs are not inappropriately used to govern live sensitive data transfers without binding legal covenants, enforcing transition to formal MOAs or MSAs.

⚠️ **How CompTIA Tests This:** Exam trigger: 'non-binding agreement defining general mutual intent and cooperation' = MOU. 'More formal agreement detailing specific shared responsibilities and obligations' = MOA.

📌 Interconnection Security Agreement (ISA) & Business Partners Agreement (BPA)

🏠 **Real-World Analogy:** Constructing an exclusive reinforced underground pneumatic tunnel with biometric vaults linking operations centers between two partner banks. The ISA is the technical engineering blueprint specifying concrete blast ratings, fiber encryption standards, and tunnel transit protocols. The BPA is the commercial charter between directors establishing profit splits, fee schedules, and corporate partnership governance.

🔍 **Root Cause & Background:** Interconnecting disparate enterprise networks via leased lines without explicit technical constraints opens lateral pathways for automated worms to traverse across partner boundaries.

🛡️ **GRC Auditor Perspective:** Audit ISA technical documentation (NIST SP 800-47): ensure precise IPsec cryptographic parameters, restricted port/IP ranges, and unilateral emergency disconnect trigger clauses are fully ratified.

⚠️ **How CompTIA Tests This:** Exam trigger: 'technical document that specifies the security requirements, encryption, and protocols for connecting two separate networks' = Interconnection Security Agreement (ISA). 'Agreement defining business expectations between commercial partners' = BPA.

⚡ QUICK-REFERENCE EXAM CHEAT SHEET

Typical Exam Scenario / Practical Situation	Technical Concept & Target Answer
Cloud hosting contract guarantees 99.99% system availability with billing credit deductions if unannounced downtime occurs	**Service Level Agreement (SLA)**
External contractor signs legal covenants promising never to disclose network diagrams or intellectual property viewed during engagement	**Non-Disclosure Agreement (NDA)**
Two institutions sign a preliminary, non-binding instrument expressing cooperative intentions for joint aerospace research	**Memorandum of Understanding (MOU)**
Official inter-agency technical agreement detailing IPsec crypto ciphers, permitted TCP ports, and direct gateway interconnection specs	**Interconnection Security Agreement (ISA)**
Two corporations execute an operational commercial contract defining profit-sharing, operational roles, and governance for a partnership	**Business Partners Agreement (BPA)**
Formal written agreement outlining specific mutual duties and financial obligations, carrying greater legal enforceability than an MOU	**Memorandum of Agreement (MOA)**

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

A cloud email security provider has repeatedly missed the availability target stated in its contract. The security manager wants a document that defines how uptime is calculated, the required support response times, and the service credits the provider must issue when targets are missed. Which agreement type should be used to document these commitments?

A) Business partnership agreement (BPA)

B) Non-disclosure agreement (NDA)

C) Service level agreement (SLA)

D) Memorandum of understanding (MOU)

QUESTION 2 · EXAM SCENARIO

Two organizations are considering a pilot project to exchange anonymized threat intelligence. They want to document their shared intent to cooperate, but neither side wants to create financial obligations or legally enforceable commitments until the pilot is successful. Which agreement type best fits this situation?

A) Memorandum of understanding (MOU)

B) Service level agreement (SLA) to ensure third-party supplier accountability and oversight

C) Business partnership agreement (BPA)

D) Statement of work (SOW) to satisfy external independent certification audit controls

QUESTION 3 · EXAM SCENARIO

Before an external forensic firm receives firewall configurations, endpoint logs, and incident reports during an active breach investigation, the legal team wants a legally enforceable promise that the firm will not disclose or misuse the sensitive data. Which agreement type should be signed?

A) Service level agreement (SLA)

B) Non-disclosure agreement (NDA)

C) Master service agreement (MSA)

D) Statement of work (SOW) while preserving chain of custody and forensic integrity

QUESTION 4 · EXAM SCENARIO

Two cybersecurity companies plan to create a jointly owned managed detection and response service. They need to define ownership percentages, revenue sharing, governance, liability, and termination conditions in a formal, legally binding arrangement. Which agreement type is most appropriate?

A) Memorandum of understanding (MOU) in accordance with documented business impact analysis criteria

B) Non-disclosure agreement (NDA) to satisfy external independent certification audit controls

C) Service level agreement (SLA) while preserving chain of custody and forensic integrity

D) Business partnership agreement (BPA)

QUESTION 5 · EXAM SCENARIO

A company expects to hire a managed security provider for multiple projects over the next three years. Legal wants one contract that establishes standard legal, payment, liability, and dispute-resolution terms for the entire relationship, while each project's scope can be added later. Which agreement type should be used for the standard terms?

A) Master service agreement (MSA)

B) Statement of work (SOW) while preserving chain of custody and forensic integrity

C) Service level agreement (SLA)

D) Memorandum of agreement (MOA)

QUESTION 6 · EXAM SCENARIO

A retail company hires a consultant for a one-time PCI DSS gap assessment. The security manager must specify the assessment deliverables, timeline, resource assignments, acceptance criteria, and fixed cost for this single engagement. Which document is most appropriate?

A) Master service agreement (MSA)

B) Memorandum of agreement (MOA)

C) Statement of work (SOW)

D) Non-disclosure agreement (NDA)

QUESTION 7 · EXAM SCENARIO

A regional bank and a threat intelligence vendor want a more formal written agreement than a simple statement of intent to document a cooperative program for joint tabletop exercises, staff exchanges, and shared research. The document will list specific activities, roles, and resources, but neither party wants it to be legally enforceable. Which agreement type best matches this need?

A) Service level agreement (SLA)

B) Business partnership agreement (BPA)

C) Non-disclosure agreement (NDA)

D) Memorandum of agreement (MOA)

QUESTION 8 · EXAM SCENARIO

During a vendor risk review, the security team finds that a critical SaaS provider has an MSA, an NDA, and a SOW, but no document states the required uptime percentage or the financial credits owed if the service falls below that percentage. Which agreement type is missing?

A) Non-disclosure agreement (NDA)

B) Service level agreement (SLA)

C) Memorandum of understanding (MOU)

D) Statement of work (SOW) to comply with mandatory regulatory governance standards

QUESTION 9 · EXAM SCENARIO

A security manager is negotiating with a SaaS vendor. Before allowing the vendor's engineers to access production data samples during a proof-of-concept, the manager wants a legally binding document that prevents them from disclosing or reusing the data for any purpose other than the evaluation. Which agreement type should be used?

A) Non-disclosure agreement (NDA)

B) Business partnership agreement (BPA)

C) Memorandum of understanding (MOU)

D) Service level agreement (SLA)

QUESTION 10 · EXAM SCENARIO

A company already has an MSA with a cloud security vendor. For a new SIEM migration, the security team needs to define the project-specific security tasks, milestones, acceptance testing, and deliverables that are not covered in the master terms. Which document should be created?

A) Service level agreement (SLA)

B) Memorandum of agreement (MOA)

C) Non-disclosure agreement (NDA)

D) Statement of work (SOW)

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option C — Service level agreement (SLA)

An SLA defines measurable service levels, such as uptime and response time, and includes remedies or penalties when the provider fails to meet them. A BPA governs a formal business partnership, an NDA protects confidential information, and an MOU records intent rather than enforceable service metrics.

Question 2: Option A — Memorandum of understanding (MOU)

An MOU is used to record a mutual understanding or intent between parties, often before a formal contract. It is generally less formal and nonbinding. An SLA defines service metrics, a BPA formalizes a business partnership, and a SOW details specific project deliverables.

Question 3: Option B — Non-disclosure agreement (NDA)

An NDA is designed to protect confidential information and create legal obligations preventing unauthorized disclosure or misuse. An SLA covers service performance, an MSA provides overarching contract terms, and a SOW defines project deliverables.

Question 4: Option D — Business partnership agreement (BPA)

A BPA is used to formally establish and govern a business partnership, including ownership, financial arrangements, responsibilities, and termination. An MOU is generally nonbinding intent, an NDA protects confidentiality, and an SLA defines service performance metrics.

Question 5: Option A — Master service agreement (MSA)

An MSA provides the overarching legal and business terms that govern all future work between parties. Individual SOWs can then define specific project scope and deliverables. An SLA defines service metrics, and an MOA records a cooperative agreement that is often nonbinding.

Question 6: Option C — Statement of work (SOW)

A SOW defines the specific work to be performed for a project, including deliverables, schedule, resources, acceptance criteria, and cost. An MSA establishes general terms for an ongoing relationship, an MOA documents a cooperative agreement, and an NDA protects confidential information.

Question 7: Option D — Memorandum of agreement (MOA)

An MOA is more formal than an MOU and can describe specific cooperative activities, roles, and resources, while often remaining nonbinding unless incorporated into a contract. An SLA defines service levels, a BPA creates a formal partnership, and an NDA protects confidential information.

Question 8: Option B — Service level agreement (SLA)

An SLA is the agreement type that records measurable service levels, such as uptime, and remedies or penalties when those levels are not met. The MSA provides general terms, the NDA protects confidentiality, and the SOW defines project deliverables.

Question 9: Option A — Non-disclosure agreement (NDA)

An NDA is used to protect confidential data and creates legal restrictions on disclosure and use. A BPA is for formal business partnerships, an MOU documents intent, and an SLA defines service performance metrics.

Question 10: Option D — Statement of work (SOW)

A SOW is used with an MSA to define the specific scope, tasks, milestones, and deliverables for a particular project. An SLA defines service metrics, an MOA records cooperative activities, and an NDA protects confidential information.